



PRODUCT DESCRIPTION (PD) DEPARTMENT OF VETERANS AFFAIRS (VA)

**Office of Information & Technology (OIT)
Veterans Integrated Service Network (VISN) 23
Diagnostic Integrated Clinical Community**

VISN 23 Consolidated Document Control

Date: 04/29/2026

VA-27-00000616

PD Version Number: 1.2

Contents

1.0	PRODUCT REQUIREMENTS	3
1.1	LOCATIONS	4
1.2	SALIENT CHARACTERISTICS	5
1.3	TRANSITION IN PLAN	10
1.4	TRANSITION CLOSEOUT AND DATA MIGRATION (OPTIONAL TASK).....	10
2.0	SaaS FEDRAMP ASSESSMENT AND AUTHORIZATION AND CONTINUOUS MONITORING REQUIREMENTS	11
2.1	IF THE SOLUTION IS FedRAMP AUTHORIZED BUT NOT VA AUTHORIZED: 11	
2.2	IF THE SOLUTION IS FedRAMP AUTHORIZED AND VA AUTHORIZED:.....	12
3.0	NOTICE OF THE FEDERAL ACCESSIBILITY LAW AFFECTING ALL INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) PROCUREMENTS (SECTION 508).....	13
3.1	SECTION 508 – INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) STANDARDS	13
3.2	COMPATABILITY WITH ASSISTIVE TECHNOLOGY	14
3.3	ACCEPTANCE AND ACCEPTANCE TESTING	14
4.0	INFORMATION TECHNOLOGY USING SUSTAINABLE PRODUCTS	14
5.0	SHIPMENT OF HARDWARE OR EQUIPMENT	14
6.0	GENERAL REQUIREMENTS.....	14
6.1	VA TECHNICAL REFERENCE MODEL	14
6.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS	15
6.3	SOCIAL SECURITY NUMBER (SSN) REDUCTION	15
6.4	INTERNET PROTOCOL VERSION 6 (IPV6).....	15
6.5	SOFTWARE AND LICENSING REQUIREMENTS	16
6.6	TRUSTED INTERNET CONNECTION (TIC)	16
6.7	GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS	16
6.7.1	AI SYSTEM/LLM DEVELOPMENT AND OPERATION DOCUMENTATION REQUIREMENTS.....	18
6.7.2	MONITORING, REPORTING, AND CORRECTIVE ACTION	19
6.7.3	AI MODEL UPDATES AND CHANGE DISCLOSURES	19
	ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE.....	20

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

1.0 PRODUCT REQUIREMENTS

The VA Midwest Health Care Network (VISN 23) - Pathology and Laboratory Medical Service requires a Document Control System to warehouse, catalog, manage and provide employee access to standard operating procedures and related documents which do not contain any form of patient identification or patient health Information. The Software as a Service (SaaS) solution must provide easy and accurate auditing of laboratory documents during accreditation inspections and provide tracking of staff training, compliance, and continuing education. The Document Control System must also provide a paperless alternative to reporting and tracking deviations from standard operating procedures. Electronic document control is critical and necessary for maintaining effective compliance with industry standards, College of American Pathologists (CAP), Clinical Laboratory Improvement Amendments (CLIA), Joint Commission (JC), Food and Drug Administration (FDA), Environmental Protection Agency (EPA), and 21 Code of Federal Regulations (CFR) Part 11 standards, Federal Risk and Authorization Management Program (FedRAMP) requirements, as well as meeting Veterans Health Administration (VHA) Patient Safety and Quality initiatives.

The Period of Performance for this effort is a base period of 12 months, with 4 12-month option periods to be exercised at the Government's discretion. The Contractor shall ensure the Document Control System is implemented and in operation within 30 business days of contract award.

Table 1: Representative Brand Name or Equivalent Items

The following table contains the MediaLab Federal brand name products that VA knows would meet the below salient characteristics (see Section 1.2). Should the Offeror propose "or equivalent" products, the Offeror shall demonstrate that the proposed product(s) meet the salient characteristics in Section 1.2 below.

Item #	Description	VISN23 Base Period Qty and each Option Period Qty (if exercised)
1	Federal Document Control (800 total users)	1
2	Federal IQE 2057 (14 sites)	1
3	Federal InspectionProof (14 sites)	1
4	Federal Compass (750 total users)	1

VISN 23 — Consolidated Document Control SystemTAC Number: **VA-27-00000616**

5	Federal Compliance & Continuing Education (CE) (600 total users)	1
6	Federal Histology CE (25 total users)	1
7	Federal Exam Simulator (11 total users)	1
8	Federal Advanced White Blood Cell (WBC) Differential Simulator (250 total users)	1
9	Federal Body Fluid Case Simulator (250 total users)	1
10	Federal Red Blood Cell (RBC) Morphology Case Simulator (250 total users)	1
11	Federal WBC Differential Simulator (250 total users)	1
12	Federal Urinalysis Simulator (250 total users)	1
13	Federal Premier Support (14 sites)	1

Table 1.**1.1 LOCATIONS**

The Contractor shall provide a laboratory document control system to each of the following VISN 23 Laboratories:

VISN Facilities	Addresses
Black Hills VA Health Care System – Fort Meade	113 Comanche Road Fort Meade, SD 57741
Black Hills VA Health Care System – Hot Springs	500 N 5th Street Hot Springs, SD 57747
Black Hills VA Health Care System – Rapid City	2165 Promise Road Rapid City, SD 57701
Central Iowa VA Health Care System – Des Moines	3600 30th Street Des Moines, IA 50310-5774
Fargo VA Health Care System	2101 Elm Street Fargo, ND 58102
Iowa City VA Health Care System	601 Highway 6 West Iowa City, IA 52246-2208
Nebraska Western Iowa VA Health Care System – Omaha	4101 Woolworth Avenue Omaha, NE 68105
Nebraska Western Iowa VA Health Care System – Lincoln	600 South 70th Street Lincoln, NE 68510-2451

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

VISN Facilities	Addresses
Nebraska Western Iowa VA Health Care System – Grand Island	2201 North Broadwell Avenue Grand Island, NE 68803-2153
Minneapolis VA Health Care System	One Veterans Drive Minneapolis, MN 55417
Twin Ports VA Clinic	3520 Tower Avenue Superior, WI 54880
Sioux Falls VA Health Care System	2501 W. 22nd Street PO Box 5046 Sioux Falls, SD 57117-5046
St. Cloud VA Health Care System	4801 Veterans Drive Saint Cloud, MN 56303

1.2 SALIENT CHARACTERISTICS

1. General Design

- a. Internet/Cloud based application, laboratory software with redundant servers and accessible from any computer 24/7, 365 days/year. Offeror must be authorized by FedRAMP **Moderate Impact Level**.
- b. Capability to secure documents, passwords, and personal information using encryption and Secure Sockets Layer (SSL). Traffic and data in motion secured and encrypted with Hypertext Transfer Protocol Secure/SSL. Data at rest encrypted with Federal Information Processing Standard (FIPS) 140-2 (or its successor) compliant encryption methods, such as Advanced Encryption Standard 256, to maintain privacy and confidentiality.
- c. Provides 99% Annual Operational Uptime and complete data retrieval capability, including a backup solution in case of catastrophic failure.
- d. Provides system server backup and contingency to ensure access to documents during planned or unplanned downtime.
- e. Simple and intuitive, menu-driven, customizable portal or user interface.
- f. Capability to re-establish existing VA employees' sign-on configurations.
- g. Modular software components that can be added or removed without requiring major upgrades or changing the functionality of the system.
- h. Multiple role or group-based permission levels that enable different levels of user access.
- i. Ability to easily add/remove user access level, and/or user.
- j. Provide total traceability – tracks who performed each task steps and each task approval.
- k. Intuitive management of the entire life cycle of a document (create, edit, approve, issue and archive).
- l. Ability to set priority tasks and reminders. Ability to assign tasks and reminders to self or other users.
- m. Ability to create customizable workflows based on department or level of importance.
- n. Ability to view documents.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

- o. Ability to create customizable reports.
- p. Ability to download full back-ups on demand.
- q. Ability to generate custom site usage reports allowing some determination of system effectiveness.
- r. Vendor Supported implementation for system being operational within 30 days of award.
- s. If required, vendor proposed solution must obtain an Authority to Operate (ATO) by VA prior to implementation.
- t. Vendor must coordinate with VA to develop and sign a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).

2. Document Control

- a. The ability to manage the entire document lifecycle from creation, approval, editing, in use status, and archiving.
- b. The ability to download multiple (in bulk) documents.
- c. Ability to link documents to forms (or to other documents).
- d. Ability to print controlled copies of documents.
- e. Capable to facilitate the use of standardized headers and formats for all sections of the lab.
- f. Capability to identify documents using a numeric or alphanumeric system and be traceable to associated forms, job aids, derivative documents or policies, etc.
- g. Capability to provide customizable design elements for the system or document control log, which includes but is not limited to; document number, name, implementation date, location of copies, last revision date/approval/version number, review date/approval, review due date, and date retired.
- h. Ability to capture the changes made between document versions and provide links for all version history between the initial version and approval.
- i. Document control log updates automatically as documents, versions, and approvals are updated.
- j. Standard file extension compatibility that allows upload of Microsoft Word (.doc, .docx, .rtf, .odt), Excel (.xls and .xlsx), PDF (.pdf), Microsoft Visio (.vsd, .vsdx), PowerPoint (.ppt and .pptx), image files (.png and .jpg/.jpeg), etc. without the need for conversion to ensure all documents display properly.
- k. Provide multiple options for document list, query, and categorize including keywords, departments, or review status.
- l. Must secure documents from editing both draft and final documents except for those assigned with those privileges.
- m. Ensures that only current policies, procedures, and forms are in use.
- n. Ability to show the 'status' of documents – i.e., draft, in approval routing, final, implemented, in review, retired.
- o. Ability to send notification emails with a link to selected employees to review new/revised procedures.

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

- p. Ability to configure and send automatic, email notifications (with embedded links) to approvers/reviewers until tasks have been completed, with automatic escalation to a higher level after predefined number of failures to complete tasks.
- q. Ability for automatic routing of new/revised documents to appropriate persons for review at appropriately configurable intervals for draft review, approval, and periodic review.
- r. Ability for frequent reviewers to retrieve documents from a list of "in review" rather than having to open each email.
- s. Ability to communicate with outside services (non-Pathology) for notification of document availability and accessibility to read documents (full network/user accessibility). Examples include the ability to share manuals with distant Community Based Outpatient Clinics and to inform wards and clinics using point of care instruments about new policies, procedures, forms and job aids, etc.
- t. Ability to audit/query records for timeliness/completion.
- u. Maintains document history in accordance with the length of time required by VHA, CLIA, JC, and CAP regulations.
- v. Allows for flexible document version control to allow for major and minor changes, to enable versioning by dates or numbers and that can be enabled and disabled. Versioning should contain limits, history, restoration, archiving, and deletion.
- w. Enables the creation of specific metadata fields for each library.
- x. Capability for current and default views of document libraries that are customizable.
- y. Allows flexibility of workflows to accommodate multiple approvers, fast track needs, delegations, or extra approvals.
- z. Ability for multiple users to access and edit documents. Multiple-user edits can be subsequently merged/reviewed for merge.

3. Regulatory Inspection Checklist Auditing and Management

- a. Suppliers must be an approved participant of CAP Accreditation Checklist Distribution Program.
- b. Ability to import/upload custom accreditation standards from common accreditation agencies (e.g. - CAP, Association for the Advancement of Blood and Biotherapies (AABB), The Joint Commission, FDA, and others).
- c. Ability to search for accreditation agency checklists.
- d. Ability to link evidence or documents to check list items.
- e. Ability for flexible workflows to delegate audits to multiple people with different levels of review.
- f. Ability to view or print report on current Accreditation Compliance.
- g. Ability to set and assign tasks to personnel, or link to document control for revisions.
- h. Capability to provide comparisons of previous year to current year accreditation standards.

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

- i. Option to transfer or update accreditation standards from previous year to current year.
- j. Ability for configurable automated reminders sent about upcoming audits and reviews that must be performed before due date.

4. Compliance and Continuing Education (CE)

- a. Access to Safety and Compliance training.
- b. Access to Histology continuing education.
- c. Access to Professional Acknowledgement for Continuing Education approved Laboratory Continuing Education courses.
- d. Ability to create training documents, links, and videos to assign to staff based on roles.
- e. Ability to create on-line exams, grading, and filing test results.
- f. Ability to monitor and track continuing education credits, and transmittal to CE Broker.

5. Reporting and Tracking: Deviations from Standard Operating Procedures/Quality Control (QC)/Maintenance

- a. Ability to customize reporting forms for tracking errors/QC/Maintenance.
- b. Provides easy access to forms by front-line staff at work locations for easy and quick reporting.
- c. Ability for Deviation Reporting to be commenced by frontline staff with the option of report being forwarded to appropriate second-level staff members for review and corrective action.
- d. Ability to track, monitor, and retrieve Deviation Reports in real-time.

6. Exam Simulation

- a. Ability to access Medical Laboratory Scientist and Medical Laboratory Technician exam questions with feedback to assist with preparation for American Society of Clinical Pathology (ASCP), American Medical Technologist (AMT), and AABB certification exams.
- b. Ability to access Histotechnician (HT) and Histotechnologist (HTL) exam questions with feedback to assist with preparation for HT and HTL certification exams.
- c. Ability to access phlebotomy exam questions with feedback to assist with preparation for ASCP, AMT, National Center for Competency Testing, National Healthcareer Association certification exams.

7. Case Simulation

- a. Ability to access in-browser virtual microscopes to teach and assess key laboratory skills.
- b. Case simulation to include RBC morphology, WBC differential including advanced WBC, body fluid, and urinalysis.

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

8. Competency Assessment Management for Waived and Non-waived Testing

- a. Ability for creation and linking competency forms through document control.
- b. Ability to schedule competency quizzes and new procedure training with reminders and due dates.
- c. Ability to send configurable and automated alerts to employees and supervisors when competency or training is approaching due date or unacceptable.
- d. Allows for staff access to their own competency and training transcript files for their review.
- e. Provides a centralized solution to provide continued education, document training, and build competency assessments for waived and non-waived testing personnel, track competency assessments status and electronically store supporting documentation.
- f. Ability to set up automatic scheduling and push assignment email notifications automatically.
- g. Ability to generate, export and print reports on demand.
- h. Ability to provide real-time progress status of competency assessments.
- i. Ability to allow access and manage to multiple users at the same time, including Point of Care non-lab testing personnel users (ability to track up to 2,000 non-lab testing personnel users).

9. System Premium Support and Maintenance

- a. Support (phone, email) must be available weekdays during normal business hours (7:00 AM CST – 11:00 PM CST).
- b. Dedicated Implementation Specialist
 - i. Monthly web-based implementation training, and ongoing support meetings;
 - 1. Training via Microsoft TEAMS, WebEx or any form of online training, including pre-recorded virtual training courses, on-line help access, Job Aids
 - 2. Continued support for all system users at different levels at no additional cost to the Government.
 - ii. Unlimited support by phone and email within one business day.
- c. Advance notification during server updates or down times.
- d. Provides sufficient storage capacity to archive all document types and workflow histories for at least five years after removal from use to meet the more stringent transfusion medicine and quality documents requirement is preferred. Alternatively, a minimal storage capacity is required for archiving transfusion service documents and review/approval history for five years, and other laboratory section records for two years.

10. Security Requirement for Cloud Services

- a. Per the Office of Management Budget (OMB), any cloud services that hold federal data must be authorized by the FedRAMP. All Federal data must be stored on a FedRAMP authorized system, and loss of FedRAMP

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

authorization is equivalent to the inability to house federal data via a cloud service. FedRAMP authorization applies to all third parties and subcontractors that the vendor uses to store federal data. Proof of FedRAMP authorization must be provided, and the vendor must disclose where all data is stored. If any data is stored by a third party and/or subcontractor, the vendor must provide proof of FedRAMP authorization for these third parties and subcontractors. FedRAMP authorization must always be maintained by the vendor and all third parties and subcontractors the vendor uses to store federal data. See Section 2.0 for Additional FedRAMP requirements.

- b. All cryptographic modules and hardware security modules must be FIPS 140-2 (or its successor) certified. The vendor must provide proof of FIPS 140-2 (or its successor) certification via a NIST approved validator. The operating platform upon which the FIP 140-2 (or its successor) certification was obtained must be maintained."

11. Installation

- a. Contractor shall provide an implementation plan, with timelines, and coordinate the initial conversion of all documents into the system.

1.3 TRANSITION-IN PLAN

The Contractor shall submit a draft Transition-In Plan with the Request for Quotation response. The draft Transition-In Plan shall be delivered for Government review allowing for comment from the Government. A finalized Transition Plan shall be delivered with incorporated Government feedback provided through a Government review within five business days of contract award. The Contractor shall implement the Transition-In Plan after the Government review and Government approval.

The Contractor's Transition-In Plan shall account for coordination with the Government and other support Contractors (for example, Contractor predecessor) that addresses the schedule for implementation and operation to include milestones, dependencies, obtaining VA ATO, and a knowledge transfer plan.

Deliverable:

- A. Transition In Plan

1.4 TRANSITION CLOSEOUT AND DATA MIGRATION (OPTIONAL TASK)

If exercised, the Contractor shall provide a Transition Out plan, with timelines, to coordinate the transfer and conversion of the complete and final backup zip file of all VISN 23 documents (via link), and other pertinent data back to the Government or to the newly incoming system and Contractor, if the incumbent system changes.

Deliverable:

- A. Transition Out Plan

2.0 SAAS FEDRAMP ASSESSMENT AND AUTHORIZATION AND CONTINUOUS MONITORING REQUIREMENTS

2.1 IF THE SOLUTION IS FEDRAMP AUTHORIZED BUT NOT VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA).
2. The Contractor shall remain in compliance with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The system must be FedRAMP Authorized at no less than the **Moderate Impact Level**.
4. The Contractor shall, where applicable, assist with the VA ATO Process to help achieve agency authorization of the cloud service or migrated application.
5. The Contractor shall provide confirmation of the completion of its FedRAMP System Security Plan (SSP) and supporting documentation by providing to the VA Program Manager, Contracting Officer's Representative, and Digital Transformation Center (DTC), its repository Identification number and associated link for VA to download the SSP and all required artifacts within five calendar days of contract award.
6. The Contractor shall work with a VA DTC Subject Matter Expert to develop and provide a VA specific system boundary diagram including any integration and connectivity components for VA use.
This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA.
7. The Contractor shall provide the results of their most recent Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP).
8. The Contractor shall complete a 3PAO Security Assessment Report (SAR).
9. The Contractor shall provide VA with the most recent monthly scans for the production environment within the authorization boundary and their scan upload schedule for FedRAMP within 30 calendar days of contract award.
10. The Contractor shall provide their availability to participate in monthly continuous monitoring meetings to be scheduled following successful VA ATO within 30 calendar days of contract award.
11. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

12. The Contractor shall comply with FedRAMP data management requirements.
13. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
14. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy.
15. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
16. The Contractor shall provide continuous monitoring activities including, but not limited to scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
17. The Contractor shall provide a Monthly VA License Report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. VAID
- B. 3PAO SAP
- C. 3PAO SAR
- D. POAM Reports
- E. Monthly VA License Report

2.2 IF THE SOLUTION IS FEDRAMP AUTHORIZED AND VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the FISMA and have a current VA authorization.
2. The Contractor shall remain in compliance with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The FedRAMP Authorization level and existing VA ATO should be no less than the level required for this use case which has been defined as **Moderate Impact Level**.
4. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency authorization of the cloud service or migrated application.
5. The Contractor shall exclusively provide subscription licenses to FedRAMP authorized and VA authorized environments.
6. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language. VA Privacy and

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

- Security deliverables as directed by the VA System owner.
7. The Contractor shall comply with FedRAMP data management requirements.
 8. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
 9. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP Website.
 10. The Contractor shall provide continuous monitoring activities including, but not limited to, scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly POAM reports as outlined by FedRAMP requirements.
 11. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
 12. The Contractor shall provide a Monthly VA License report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. Continuous Monitoring Monthly Scans
- B. POAM Reports.
- C. Monthly VA License Report

3.0 NOTICE OF THE FEDERAL ACCESSIBILITY LAW AFFECTING ALL INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) PROCUREMENTS (SECTION 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

3.1 SECTION 508 – INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) STANDARDS

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](#). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with “508 Chapter 2: Scoping Requirements” for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

3.2 COMPATABILITY WITH ASSISTIVE TECHNOLOGY

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

3.3 ACCEPTANCE AND ACCEPTANCE TESTING

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

4.0 INFORMATION TECHNOLOGY USING SUSTAINABLE PRODUCTS

N/A

5.0 SHIPMENT OF HARDWARE OR EQUIPMENT

N/A

6.0 GENERAL REQUIREMENTS

6.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.3 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the Integrated Control Number (ICN) in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA Master Person Index (MPI) for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

(<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 “USGv6 Profile” (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 “Guidelines for the Secure Deployment of IPv6” (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.5 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor’s proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.6 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative” (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 “Secure External Connections”, and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>.)

6.7 GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS

If Artificial Intelligence (AI) is part of the Contractor system/solution, the Contractor shall be in compliance with E.O. 13960 and 14319, OMB Memorandums M-25-21, M-25-22, and M-26-04, and VA Directive and Handbook 6500 to support VA in trustworthy, secure, responsible, accountable, Truth Seeking, and Ideologically Neutral AI innovation.

No web-based, publicly available generative AI service has been approved for use with VA-sensitive data including, but not limited to OpenAI’s ChatGPT, Microsoft’s Copilot, Google’s Gemini, and Anthropic’s Claude. No PII, protected health information (PHI), or VA-sensitive data should be entered into these unapproved services. The entire definition of VA Sensitive Data can be found at 38 U.S.C. § 5727 (23). The Contractor shall protect VA Sensitive data from unauthorized disclosure or use, and from being

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

used to train or improve the functionality of the vendor's commercial offerings without express permission from VA.

The Contractor shall deliver the services, technical data, configurations, models, weights, documentation or other information, including source code, developed during contract performance. The Contractor, in collaboration with VA, must evaluate the output of any AI tool for accuracy prior to using the output in VA efforts. All data, including models, weights, algorithms, and outputs generated using either Government-furnished data or data first developed under this contract shall be the property of the Government with unlimited rights as defined by FAR 52.227-14. The Contractor shall also deliver any custom-developed code developed with AI methodologies in accordance with the SHARE IT Act, if applicable. VA shall also retain unlimited rights to any improvements to that data, including the continued design, development, testing, and operation of AI systems and/or systems utilizing AI.

The Contractor shall ensure that all AI Systems, including Large Language Models (LLM), whether standalone LLMs or integrated into broader software platforms, procured under this effort and/or used in performance of this contract complies with the Unbiased AI Principles as defined in Executive Order 14319 and OMB Memorandum M-26-04, e.g. Truth Seeking and Ideologically Neutral, as applicable to the intended use of the system.

The Contractor shall ensure that AI System/LLM generated outputs are truthful in responding to user prompts seeking factual information or analysis, prioritize historical accuracy, scientific inquiry, and objectivity, as well as acknowledge uncertainty where reliable information is incomplete or contradictory and do not fabricate, hallucinate, or present unverifiable information as fact.

The Contractor shall ensure that LLMs and AI outputs are neutral, nonpartisan tools that do not manipulate responses in favor of ideological dogmas such as Diversity, Equity, and Inclusion (DEI). The Contractor shall ensure that the LLMs, including the AI System, are not intentionally encoded with partisan or ideological judgments within an AI System's/LLM's outputs unless those judgments are prompted by or otherwise readily accessible to the end user.

Compliance with the AI requirements of this contract, including adherence to the Unbiased AI Principles, Truth-Seeking and Ideological Neutrality requirements, disclosure obligations, monitoring and reporting requirements, and corrective action responsibilities, is a material condition of eligibility for payment and continued performance. In accordance with OMB Memorandum M-26-04, failure to comply with these requirements, or refusal to take timely and appropriate corrective action to remedy identified noncompliance, may constitute a material breach of contract and may result in remedies consistent with the terms of the contract and applicable law including but not limited to withholding of payment, termination for cause/default, or other appropriate contractual remedies, as determined by the Contracting Officer.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

All AI for delivery and/or use in performance of the contract shall adhere to the VA *Trustworthy AI Framework*, available at <https://department.va.gov/ai/trustworthy/>. Once the Contractor has obtained CO authorization to use specific AI in contract performance, the Contractor shall provide the COR a signed Statement of Attestation prior to AI implementation as identified in the Artificial Intelligence in VA Contracts clause, to include its associated list of AI being used in contract performance.

Deliverable:

- A. Statement of Attestation

6.7.1 AI SYSTEM/LLM DEVELOPMENT AND OPERATION DOCUMENTATION REQUIREMENTS

To enable Government continued assessment of compliance with Trustworthy AI requirements and both Unbiased AI Principles, Truth-seeking and Ideological Neutrality, in accordance with OMB M-26-04, the Contractor shall provide AI System/LLM Development and Operation Documentation Package to include, at a minimum:

1. Acceptable Use Policy

The Contractor shall provide an Acceptable Use Policy document governing its AI operation that characterizes and differentiates appropriate and inappropriate use of their product offering

2. Model Cards, System Cards and/or Data Cards

The Contractor shall provide documentation describing essential information about the model, system, and or data as it relates to the AI/LLM product offering. The documentation shall address summaries of training process, identified risks and mitigations, and model evaluation scores on LLM benchmarks at a minimum, where appropriate

3. End User Resources

The Contractor shall provide documentation to include product tutorials, developer guides, and/or other tools to assist VA in ensuring proper use of the AI/LLM to maximize utility

4. Mechanism for End User Feedback

The Contractor shall provide documentation describing the mechanism employed to provide feedback to the Offeror on outputs identified that violate the Unbiased AI Principles. This may be satisfied by a general inbox, specific Point of Contact, or similar feedback mechanism.

Deliverable:

- A. AI System/LLM Development and Operation Documentation Package

6.7.2 MONITORING, REPORTING, AND CORRECTIVE ACTION

The Contractor shall develop and implement a Compliance Monitoring and Reporting Plan supporting ongoing monitoring processes to evaluate AI outputs for compliance with Trustworthy AI and Unbiased AI principles. This plan shall include the mechanism for authorized users to provide end user feedback to report suspected violations of Truth-Seeking or Ideological Neutrality requirements.

The Contractor shall notify the COR within 10 business days of identifying any material deviation from these principles and shall submit a written Corrective Action Plan describing mitigation steps, responsible parties, and timelines. Any material deviation, corrective action taken, and results shall be detailed in a weekly progress report.

Deliverable:

- A. Compliance Monitoring and Reporting Plan
- B. Corrective Action Plan

6.7.3 AI MODEL UPDATES AND CHANGE DISCLOSURES

The Contractor, in an AI Model/LLM Change Disclosure, shall notify the Government throughout the PoP in advance of any material changes to AI models, including new AI enhancements, features and/or components, controls, retraining, classifiers, system prompts, fine-tuning, content moderation, filters, version replacement, or architectural changes, that could reasonably affect compliance with Trustworthy AI or Unbiased AI principles. Updated documentation shall be provided to VA for VA approval prior to implementation of such changes.

Deliverable:

- A. AI Model/LLM Change Disclosure

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/
PRIVACY LANGUAGE**

NOTE: In the event of a conflict, VA Acquisition Regulation (VAAR) Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS TAILORED FROM: VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

(including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.

- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

N/A

B4. TRAINING

N/A

B5. SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

- e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
- f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- a. Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).
- b. Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.

- c. VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.
- d. The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-26-05 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change. The term “software” includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO)14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one approved by the agency will be acceptable in lieu of a software producer's self-attestation.
- e. The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- f. The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

- g. The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,
- h. The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default “program files” directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- i. Applications designed for normal end users will run in the standard user context without elevated system administration privileges.
- j. The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this will only be granted with the written approval of the COR/CO.
- k. The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- l. The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- m. The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as “Information Systems”) throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations, workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems (including systems, operating systems, products, hardware, software,

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.

- n. When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.
- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.
- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.

VISN 23 — Consolidated Document Control System

TAC Number: VA-27-00000616

- c. The Contractor shall provide or arrange for the provision of technical justification as to why any “false positive” hit has taken place to ensure their code’s supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.
- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter “virus or other malware”) onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA’s information networks, computer systems and information systems; and
 - (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor’s products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:

- (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
 - c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
 - d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

- a. Contractor supplies/delivered Medical Devices, Special Purpose Systems-Operational Technology (SPS-OT) and Research Scientific Computing Devices shall comply with all applicable Federal law, regulations, and VA policies. New developments require creation, testing, evaluation, and authorization in compliance with processes specified on the Specialized Device Cybersecurity Department Enterprise Risk Management (SDCD-ERM) Portal, VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, VA Handbook 6500, and the VA Information Security Knowledge Service. Deviations from Federal law, regulations, and VA Policy are

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

identified and documented as part of VA Directive 6550 and/or the VA Enterprise Risk Analysis (ERA) processes for Specialized Devices/Systems processes.

- b. All Contractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500 and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO for governance or resolution.
- c. The Contractor shall certify to the COR/CO that devices/systems that have completed the VA Enterprise Risk Analysis (ERA) process for Specialized Devices/Systems are fully functional and operate correctly as intended. Devices/systems must follow the VA ERA authorized configuration prior to acquisition and connection to the VA computing environment. If VA determines a new VA ERA needs to be created, the Contractor shall provide required technical support to develop the configuration settings. Major changes to a previously approved device/system will require a new ERA.
- d. The Contractor shall comply with all practices documented by the Food Drug and Administration (FDA) Premarket Submission for Management of Cybersecurity in Medical Devices and Postmarket Management of Cybersecurity in Medical Devices.
- e. The Contractor shall design devices capable of accepting all applicable security patches with or without the support of the Contractor personnel. If patching can only be completed by the Contractor, the Contractor shall commit the resources needed to patch all applicable devices at all VA locations. If unique patching instructions or packaging is needed, the Contractor shall provide the necessary information in conjunction with the validation/testing of the patch. The Contractor shall apply security patches within 30 business days of the patch release and have a formal tracking process for any security patches not implemented to include explanation when a device cannot be patched.
- f. The Contractor shall provide devices able to install and maintain VA-approved antivirus capabilities with the capability to quarantine files and be updated as needed in response to incidents. Alternatively, a VA-approved whitelisting application may be used when the Contractor cannot install an anti-virus / anti-malware application.
- g. The Contractor shall verify and document all software embedded within the device does not contain any known viruses or malware before delivery to or installation at a VA location.
- h. Devices and other equipment or systems containing media (hard drives, optical disks, solid state, and storage via chips/firmware) with VA sensitive information

VISN 23 — Consolidated Document Control System

TAC Number: **VA-27-00000616**

will be returned to the Contractor with media removed. When the contract requires return of equipment, the options available to the Contractor are the following:

- (1) The Contractor shall accept the system without the drive, firmware and solid state.
- (2) VA's initial device purchase includes a spare drive or other replacement media which must be installed in place of the original drive at time of turn-in; or
- (3) Due to the highly specialized and sometimes proprietary hardware and software associated with the device, if it is not possible for VA to retain the hard drive, firmware, and solid state, then:
 - (a) The equipment Contractor shall have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact.
 - (b) Any fixed hard drive, Complementary Metal-Oxide-Semiconductor (CMOS), Programmable Read-Only Memory (PROM), solid state and firmware on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the solicitation, contract, or order.

B14. DATA CENTER PROVISIONS

N/A

POINTS OF CONTACT (To be inserted at award)

VA Program Manager:

Name:

Address:

Voice:

Email:

Contracting Officer's Representative:

Name:

Address:

Voice:

Email:

Contracting Officer:

Name:

Address:

Voice:

Email:

Contract Specialist:

Name:

Address:

Voice:

Email:

INFORMATION SECURITY CONSIDERATIONS

All VA sensitive information shall be protected at all times in accordance with local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this Product Description.

DRAFT